

Área de Conocimiento de Tecnología de la Información y Comunicación

Auditoría de Sistemas

Informe preliminar de auditoría de redes en el SILAIS Sede Masaya, Nicaragua

Elaborado por:

Br. Gerson Antonio
Valdivia

Br. Haxell Antonio
Trejos Rodríguez

Br. Alison Michelle
Navarro Goussen

Br. Stephanie Lucía
Mora Chávez

Br. Arleth del Rosario
Velásquez Gómez

Docente:

Msc. Leonel Antonio Martínez Zuniga

09 de mayo, 2026
Managua, Nicaragua

I. INTRODUCCIÓN

Los Sistemas Locales de Atención Integral en Salud (SILAIS) en Nicaragua constituyen la base operativa descentralizada del Ministerio de Salud (MINSA) para la prestación de servicios de salud a nivel departamental. El SILAIS – Sede Masaya, como entidad responsable de la vigilancia epidemiológica y la atención integral en salud del departamento de Masaya, depende de manera crítica de su infraestructura de red de datos para la operación del Sistema Nicaragüense de Vigilancia Epidemiológica Nacional (SISNIVEN), la transmisión oportuna de información al MINSA Central, y la coordinación administrativa entre sus catorce áreas funcionales.

La presente auditoría de redes se enfoca en la evaluación integral de la infraestructura física y la arquitectura lógica de la red de área local (LAN) del SILAIS – Sede Masaya. El análisis abarca desde el nodo central de telecomunicaciones, los medios de transmisión, los equipos de conmutación, hasta la configuración lógica, la seguridad de la red y las políticas de control de acceso, excluyendo el hardware de cómputo de los usuarios finales.

Para el desarrollo de esta auditoría se ha adoptado el marco de trabajo COBIT 2019 y el dominio DSS (Entregar, Dar Servicio y Soporte) y sus procesos: DSS01 – Gestión de Operaciones, DSS02 – Gestión de Solicitudes e Incidentes, DSS03 – Gestión de Problemas, DSS04 – Gestión de la Continuidad y DSS05 – Gestión de Servicios de Seguridad como referencia metodológica principal, complementado con los estándares internacionales ISO/IEC 27001:2022 para la seguridad de la información, ANSI/TIA/EIA para el cableado estructurado, e ISO 19011:2018 para la gestión del proceso de auditoría. Este enfoque permite evaluar de manera sistemática la gobernanza, gestión, desempeño y seguridad de la infraestructura de red, generando hallazgos objetivos, recomendaciones accionables y un plan de mejora priorizado que fortalezca la capacidad del SILAIS para cumplir su misión institucional.

II. OBJETIVOS DE LA AUDITORIA

OBJETIVO GENERAL

Realizar una Auditoria de Redes en la estructura física y lógica en el SILAIS - Sede Masaya, utilizando el marco de trabajo COBIT 2019 y su dominio DSS (Entregar, Dar Servicio y Soporte) y los procesos: DSS01 – Gestión de Operaciones, DSS02 – Gestión de Solicitudes e Incidentes, DSS03 – Gestión de Problemas, DSS04 – Gestión de la Continuidad y DSS05 – Gestión de Servicios de Seguridad a fin de identificar su estado actual y emitir recomendaciones necesarias que permitan a la institución mejorar su infraestructura.

OBJETIVOS ESPECIFICOS

- Desarrollar la planificación y programación de la auditoría de redes, estableciendo el organigrama del equipo auditor, el plan de trabajo y la asignación de recursos para la evaluación de la infraestructura física y lógica de la red.
- Elaborar un diagnóstico informático y un análisis de gestión de riesgos de la red de datos del SILAIS Masaya para identificar vulnerabilidades iniciales.
- Aplicar la auditoría a la infraestructura física y arquitectura lógica de la red mediante metodologías y normativas internacionales vigentes.
- Efectuar un informe final de auditoría informática que incluya la valoración de los componentes evaluados, junto con las recomendaciones pertinentes orientadas a la estandarización y optimización de la infraestructura y los procesos de red.

III. ALCANCE DE LA AUDITORIA

La auditoría abarcará la evaluación del diseño, implementación y administración de la red de área local (LAN) del SILAIS - Sede Masaya. El trabajo se limitará a la infraestructura de red interna de la sede departamental, abarcando desde el nodo central de telecomunicaciones hasta los puntos de conexión de red en las estaciones de trabajo de los usuarios, excluyendo la evaluación del hardware de cómputo de las estaciones de trabajo.

La auditoría se realizará tomando como marco de referencia los procesos de COBIT 2019 que tienen relación directa con la infraestructura de redes informáticas, específicamente el dominio DSS (Entregar, Dar Servicio y Soporte) y los procesos: DSS01, DSS02, DSS03, DSS04y DSS05, complementados con los estándares ANSI/TIA/EIA para cableado estructurado e ISO/IEC 27001:2022 para seguridad de las comunicaciones. El período de evaluación comprenderá la situación actual de la infraestructura de red al momento de la ejecución de la auditoría, considerando la documentación disponible y la evidencia recolectada durante el trabajo de campo en las instalaciones del SILAIS - Sede Masaya.

El alcance del proyecto comprende específicamente las siguientes áreas:

- **Infraestructura de Hardware de Red:** Evaluación del estado físico, capacidad operativa, antigüedad tecnológica y ubicación de los equipos centrales de conmutación (Dos Switches Principales Fast Ethernet de 24 puertos no administrables ubicados en Dirección y un Switch Secundario Fast Ethernet de 24 puertos no administrable ubicado en Varios 1), verificación de la existencia y estado de sistemas de respaldo eléctrico (UPS en cada switch), y análisis de las condiciones ambientales y de seguridad física de las áreas de comunicaciones.
- **Medios de Transmisión (Capa Física):** Inspección técnica de los tendidos de cableado estructurado que conectan las catorce áreas funcionales del SILAIS, verificación de la categoría del cableado instalado y su capacidad para soportar velocidades superiores a 100 Mbps, verificación de la norma de ponchado T568A en los conectores RJ45, evaluación de la existencia y estado de canaletas plásticas (presentes únicamente en Banco Biológico, Sindicato, Dirección y FET Salud), verificación de la ausencia de rosetas de pared, ausencia de patch panels y ausencia de patch cords, revisión de la rotulación de puntos de red y condiciones físicas de las canalizaciones y rutas de cableado. Incluye pruebas de continuidad con cable tester en puntos de red de áreas críticas.

- **Arquitectura Lógica y Seguridad de Red:** Revisión exhaustiva de la topología de red implementada, esquema de direccionamiento IP, configuración del servidor DHCP, existencia o ausencia de segmentación de tráfico mediante VLANs para el aislamiento de áreas críticas (Epidemiología, Banco Biológico, Estadística) respecto a áreas administrativas (Contabilidad, RRHH) y de uso compartido (Varios 1, 2 y 3), verificación de la velocidad de negociación de enlace limitada a 100 Mbps por los switches Fast Ethernet, evaluación de los mecanismos de control de acceso a la red, análisis de la seguridad de la red inalámbrica en las áreas que dependen de conectividad WiFi (Estadística, Contabilidad, RRHH, Insumos Médicos, Enfermería, Dirección), y evaluación de la gestión de las conexiones privadas en Sindicato, SNC y Transporte.
- **Gestión y Gobernanza de la Red:** Evaluación de la existencia de políticas documentadas para la administración de la red, inventario de activos de red, gestión de configuraciones de switches y puntos de acceso, procedimientos de control de cambios en la infraestructura de red, registro de incidentes de conectividad, plan de continuidad operativa y recuperación ante desastres para la infraestructura de comunicaciones, y designación formal de un responsable de la administración de la red.

IV. ÁREAS A AUDITAR

Área Funcional	Equipos Escritorio	Laptops	Tipo Conectividad	Datos Sensibles Procesados
Epidemiología	6	0	100% LAN	Datos SISNIVEN, brotes, mortalidad
Varios 1	10	0	LAN (Switch 24p)	Información general/diversa
Varios 2	3	0	2 LAN, 1 WLAN	Información general/diversa
Varios 3	4	0	100% LAN	Información general/diversa
Estadística	3	0	1 LAN, 2 WLAN	Datos estadísticos SISNIVEN, boletines
Contabilidad	3	0	100% WLAN	Información financiera, nóminas
RRHH	3	0	2 WLAN, 1(implícito)	Datos personales de personal sanitario
Insumos Médicos	3	0	100% WLAN	Inventario farmacéutico, caducidades
Enfermería	2	0	100% WLAN	Protocolos de atención, turnos

Área Funcional	Equipos Escritorio	Laptops	Tipo Conectividad	Datos Sensibles Procesados
Dirección/FET Salud	1	2	1 LAN, 2 WLAN	Información estratégica confidencial
SNC	2	2	Conexión Privada	Datos de salud comunitarios sensibles
Administración	1	0	LAN	Información presupuestaria
Caja	2	0	LAN	Transacciones financieras
Banco Biológico	1	0	LAN	Muestras biológicas, resultados VIH/TB
Sindicato	2	0	Conexión Privada	Información gremial
Transporte	0	1	Conexión Privada	Logística operativa
TOTAL	46	5		

V. METODOLOGÍA DE LA AUDITORÍA

Para la ejecución de esta auditoría integral de infraestructura de red del SILAIS - Sede Masaya, se aplicarán técnicas de inspección ocular de la infraestructura física de comunicaciones, análisis de configuración lógica de los dispositivos de red, pruebas de conectividad y rendimiento, revisión documental de políticas y registros de gestión de red, y entrevistas estructuradas con el personal clave de las áreas funcionales. Las actividades operativas y las herramientas normativas a utilizar son:

- **Levantamiento del mapa topológico físico y lógico de la red** del SILAIS Masaya para contrastarlo con la documentación existente, identificando la interconexión de los dos switches Fast Ethernet de 24 puertos no administrables, la topología en estrella, la distribución de puntos de red hacia las catorce áreas funcionales, la ubicación y configuración de los puntos de acceso inalámbrico que dan servicio a las áreas con dependencia de conectividad WiFi (Estadística, Contabilidad, Insumos Médicos, Enfermería, RRHH y Dirección), y el trazado de las conexiones privadas en Sindicato, SNC y Transporte.
- **Ejecución de un Checklist de inspección física** en el nodo central de comunicaciones ubicado en el área de Dirección (Switch Principal Fast Ethernet de 24 puertos) y en el punto de distribución secundario ubicado en el área de Varios 1 (Switch Secundario Fast Ethernet de 24 puertos), verificando las condiciones de seguridad física, ausencia de rack o gabinete cerrado, ordenamiento de cables, ausencia de patch panels, canalizaciones físicas presentes únicamente en cuatro áreas, condiciones de ventilación y exposición a polvo ambiental de los equipos de conmutación, y la existencia y estado de los sistemas de respaldo eléctrico (UPS) para la protección de cada switch, en el marco de los procesos **DSS01 (Gestión de Operaciones)** y **DSS05 (Gestión de Servicios de Seguridad)**.
- **Inspección técnica del cableado estructurado** en las catorce áreas funcionales, verificando la categoría del cableado UTP instalado, el cumplimiento de la norma de ponchado T568A en los conectores RJ45, la presencia o ausencia de canaletas plásticas de protección, la existencia de rosetas de pared y patch panels, el uso de patch cords flexibles, la rotulación de puntos de red y las condiciones físicas de las rutas de cableado, contrastando los hallazgos con los estándares ANSI/TIA/EIA-568-C, ANSI/TIA/EIA-569-C y ANSI/TIA/EIA-606-B, en el marco del proceso **DSS01 (Gestión de Operaciones)**.
- **Pruebas de continuidad con cable tester** en puntos de red seleccionados de áreas críticas (Epidemiología, Estadística, Banco Biológico, Contabilidad y Dirección), para verificar la integridad de los ocho pines en cada enlace, la

correcta secuencia de ponchado según norma T568A, y detectar posibles fallos de conectividad física que afecten la transmisión de datos, en el marco del proceso **DSS01 (Gestión de Operaciones)**.

- **Pruebas de conectividad y verificación de velocidad de enlace** en puntos de red de áreas críticas y de uso compartido, utilizando comandos de red (ipconfig /all, propiedades del adaptador) para determinar la velocidad real de negociación de las tarjetas de red con los switches Fast Ethernet, confirmar la operación a 100 Mbps y cuantificar el nivel de estrangulamiento operativo documentado en el diagnóstico preliminar, en el marco del proceso **DSS01 (Gestión de Operaciones)**.
- **Análisis de configuración lógica de la red**, incluyendo la verificación del esquema de direccionamiento IP y la asignación DHCP mediante comandos ipconfig /all en equipos de diferentes áreas funcionales, la comprobación de la topología de red plana sin segmentación VLAN mediante pruebas de ping entre equipos de áreas con diferentes niveles de sensibilidad de datos (Varios 1 a Epidemiología, Varios 1 a Banco Biológico), y la verificación de la ausencia de listas de control de acceso, políticas de calidad de servicio y mecanismos de seguridad de puertos que restrinjan la comunicación entre áreas, en el marco del proceso **DSS05 (Gestión de Servicios de Seguridad)**.
- **Evaluación de la seguridad de la red inalámbrica** en las áreas con dependencia de conectividad WiFi (Estadística, Contabilidad, Insumos Médicos, Enfermería, RRHH y Dirección), verificando los protocolos de cifrado implementados (WPA2, WPA3), los mecanismos de autenticación utilizados, la intensidad de señal en los puntos de trabajo críticos mediante herramientas de análisis WiFi, y la existencia de medidas de control de acceso a la red inalámbrica, en el marco del proceso **DSS05 (Gestión de Servicios de Seguridad)**.
- **Verificación de las conexiones privadas a Internet** en Sindicato, SNC y Transporte, documentando el tipo de conexión, proveedor de servicios, medidas de seguridad implementadas, grado de integración con la red corporativa del SILAIS, y evaluación de los riesgos de fuga de información a través de estos canales no monitoreados por la administración de TI, en el marco del proceso **DSS05 (Gestión de Servicios de Seguridad)**.
- **Revisión de la gestión de operaciones y servicios de red** utilizando los lineamientos de los procesos COBIT 2019 del dominio DSS, evaluando la existencia de políticas documentadas para la administración de la infraestructura de red (DSS01), la gestión de inventario de activos de telecomunicaciones (DSS01), la existencia de procedimientos de registro y resolución de incidentes

de conectividad (DSS02), el análisis de problemas recurrentes de red (DSS03), la existencia de planes de continuidad operativa para la infraestructura de comunicaciones que soporta el SISNIVEN (DSS04), y los controles de seguridad implementados en la red (DSS05).

- **Evaluación de la gestión de riesgos tecnológicos** en el SILAIS Masaya basándose en los procesos **DSS03 (Gestión de Problemas)** y **DSS05 (Gestión de Servicios de Seguridad)** de COBIT 2019, verificando si la Alta Dirección ha establecido un proceso formal para la identificación, análisis y tratamiento de los riesgos asociados a la infraestructura de red, particularmente aquellos relacionados con la obsolescencia tecnológica de los switches Fast Ethernet, la topología de red plana sin segmentación, la dependencia de conectividad inalámbrica en áreas críticas, y la existencia de puntos únicos de falla en la arquitectura de comunicaciones.
- **Revisión de la seguridad lógica y protección de los datos en tránsito** que manejan las áreas de Epidemiología, Banco Biológico y Estadística, basándose en el proceso **DSS05 (Gestión de Servicios de Seguridad)** de COBIT 2019, verificando la existencia de controles de acceso a la red, mecanismos de autenticación para la conexión de dispositivos, políticas de segmentación de tráfico, y medidas de protección para la transmisión de datos epidemiológicos hacia el MINSA Central.
- **Evaluación de la estructura física de transmisión** (cableado UTP, terminaciones y conectores) en una muestra representativa de puntos de red de las catorce áreas funcionales, contrastándola con los estándares de telecomunicaciones ANSI/TIA/EIA-568-C para determinar la categoría del cableado instalado, su capacidad para soportar velocidades superiores a 100 Mbps, la calidad de las terminaciones, y la conformidad del ponchado con la norma T568A, en el marco del proceso **DSS01 (Gestión de Operaciones)**.
- **Entrevistas estructuradas con el personal responsable de las áreas críticas**, incluyendo al Responsable de Epidemiología (Lic. Genory Ticay López), Responsable de Estadística (Lic. Alexander Valle López), Responsable de Insumos Médicos (Lic. Raymundo García), y Responsable de Planificación (Lic. Gardenio Miranda), para documentar los procedimientos operativos actuales en materia de uso de la red, las dificultades técnicas experimentadas en conectividad, las necesidades no satisfechas en materia de infraestructura de comunicaciones, y la percepción del personal sobre la disponibilidad y seguridad de la red institucional.
- **Evaluación del nivel de madurez de los procesos del dominio DSS de COBIT 2019** aplicables a la infraestructura de red del SILAIS Masaya, utilizando

la escala de capacidad de procesos de 0 a 5 establecida por el marco de referencia, para cada uno de los procesos evaluados durante la auditoría: **DSS01 (Gestión de Operaciones de Red)**, **DSS02 (Gestión de Solicitudes e Incidentes de Red)**, **DSS03 (Gestión de Problemas de Red)**, **DSS04 (Gestión de Continuidad de la Red)** y **DSS05 (Gestión de Servicios de Seguridad de Red)**.

VI. HALLAZGOS DE INFRAESTRUCTURA DE HARDWARE DE RED
HALLAZGO No. H-RED-INFRA-01

SILAIS – SEDE MASAYA		REF: H-RED-INFRA-01		
HALLAZGOS DE LA AUDITORIA		H1		
PROCESO AUDITADO	Seguridad física de la infraestructura de red	PAGINA		
		1	DE	1
RESPONSABLE				
CRITERIO	ISO 27001 A.11.1, ANSI/TIA-569-C, COBIT DSS05			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS05 – Gestión de Servicios de Seguridad	
DESCRIPCIÓN DEL HALLAZGO				
No existe un rack o gabinete de telecomunicaciones cerrado con llave para alojar los switches. Los dos switches principales ubicados en el área de Dirección se encuentran sobre un soporte metálico, y el switch secundario ubicado en el área de Varios 1 se encuentra sobre la gaveta metálica de un escritorio. Esta condición deja los puertos de red y los equipos expuestos a manipulación accidental o malintencionada por parte de personal no autorizado, visitantes o personal de limpieza.				
CAUSAS				
- Inexistencia de un responsable formal de la administración de la red que identifique y gestione las necesidades de protección física de los equipos. - Ausencia de políticas institucionales de seguridad física aplicadas a los activos de telecomunicaciones. - Falta de presupuesto priorizado para la instalación de racks o gabinetes de protección.				
EVIDENCIA				
- Fotografías del área de Dirección y Varios 1 que muestran los switches sobre soportes metálicos y gavetas de escritorio, sin protección. - Checklist de inspección física Módulo I, criterio F-01: ¿Los equipos de red centrales están alojados de forma segura dentro de un Gabinete o Rack cerrado con llave? Respuesta: NO.				
IMPACTO				
- Riesgo de conexión no autorizada de dispositivos a la red LAN del SILAIS. - Exposición a daños físicos por golpes accidentales o derrame de líquidos. - Mayor acumulación de polvo y suciedad en los equipos, acelerando su degradación.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
R-RED-011: Conexión de dispositivos no autorizados a la red	Alto (3)	Media (3)	Alto (9)	
R-RED-008: Fallo prematuro de switches por acumulación de polvo	Alto (3)	Alta (4)	Alto (12)	
RECOMENDACIONES				
Inmediata (0-15 días): Adquirir e instalar un rack o gabinete de pared con cerradura en el área de Dirección para alojar los switches principales y su UPS. Inmediata (0-15 días): Adquirir e instalar un rack o gabinete de pared con cerradura en el área de				

Varios 1 para alojar el switch secundario y su UPS.

3. **Corto plazo (30-60 días):** Designar formalmente a un responsable de la administración de la red que tenga entre sus funciones el control de acceso físico a los dispositivos de comunicación.

HALLAZGO No. H-RED-INFRA-02

SILAIS – SEDE MASAYA			REF: H-RED-INFRA-02		
HALLAZGOS DE LA AUDITORIA			H2		
PROCESO AUDITADO	Gestión operativa de la red – Mantenimiento de infraestructura		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	COBIT DSS01, ISO 27001 A.11.2.4				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS01 – Gestión de Operaciones		
DESCRIPCIÓN DEL HALLAZGO					
No existe un programa documentado de mantenimiento preventivo para los equipos de comunicación (switches y UPS). Las actividades de limpieza, verificación de ventiladores y comprobación de baterías de UPS no se realizan de manera programada. La supervisión del estado operativo de estos equipos es reactiva, atendiendo únicamente los fallos que son reportados por los usuarios.					
CAUSAS					
- Inexistencia de un responsable de red designado formalmente. - Falta de políticas y procedimientos documentados para la gestión de operaciones de red. - Cultura organizacional reactiva, enfocada en resolver incidencias en lugar de prevenirlas.					
EVIDENCIA					
- Respuesta negativa a la solicitud de cronogramas o bitácoras de mantenimiento preventivo. - Checklist Módulo I, criterio F-05: Área con ventilación y limpieza adecuada. Respuesta: NO. - Entrevistas con personal de Planificación.					
IMPACTO					
- Degradación progresiva de los equipos de comunicación. - Reducción significativa de la vida útil de los switches y UPS. - Mayor probabilidad de fallos inesperados durante picos de operación.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
R-RED-008: Fallo prematuro por falta de mantenimiento preventivo	Alto (3)	Alta (4)	Alto (12)		
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
RECOMENDACIONES					
1. Corto plazo (30-60 días): Elaborar un programa de mantenimiento preventivo semestral que incluya limpieza interna y externa de switches, verificación del funcionamiento de ventiladores y					

comprobación de la autonomía de las baterías de las UPS.

2. Corto plazo: Asignar al responsable de red la ejecución y documentación de estas tareas en bitácoras formales.

HALLAZGO No. H-RED-INFRA-03

SILAIS – SEDE MASAYA		REF: H-RED-INFRA-03		
HALLAZGOS DE LA AUDITORIA		H3		
PROCESO AUDITADO	Gestión operativa de activos de red – Cableado estructurado		PAGINA	
			1	DE 1
RESPONSABLE				
CRITERIO	ANSI/TIA-568-C, ANSI/TIA-569-C, ISO 27001 A.11.2, COBIT DSS01			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS01 – Gestión de Operaciones	
DESCRIPCIÓN DEL HALLAZGO				
La infraestructura de cableado estructurado presenta serias deficiencias. En diez de las catorce áreas funcionales el cableado UTP se encuentra expuesto, sin la protección de canaletas plásticas. No se utilizan patch panels ni patch cords; el cableado horizontal sólido se conecta directamente a los puertos de los switches. Tampoco existen rosetas de pared en los puntos de trabajo, quedando los conectores RJ45 colgando directamente, sometidos a tensión constante.				
CAUSAS				
• Instalación inicial de la red sin la supervisión de un profesional certificado en estándares de cableado estructurado. • Falta de presupuesto para completar la instalación de canaletas y la adquisición de patch panels y rosetas. • Desconocimiento de los estándares ANSI/TIA/EIA por parte del personal que ha manipulado la red.				
EVIDENCIA				
• Fotografías del cableado expuesto, torceduras y conectores RJ45 colgando. • Checklist Módulo II (Cableado y Canalización) y Módulo III (Área de Trabajo), con múltiples criterios evaluados negativamente.				
IMPACTO				
• Alta probabilidad de rotura de conductores y fallos intermitentes de conectividad. • Daño a los puertos de los switches por la tensión del cable sólido horizontal. • Dificultad para realizar tareas de mantenimiento y una imagen de desorden generalizada.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado		Impacto	Probabilidad	Nivel de Riesgo
R-RED-009: Interrupción de conectividad por daño al cableado expuesto		Medio (2)	Alta (4)	Alto (8)
RECOMENDACIONES				
1. Corto plazo (30-60 días): Completar la instalación de canaletas plásticas en las diez áreas que carecen de protección. 2. Corto plazo: Instalar patch panels de 24 puertos en ambos nodos y rosetas de pared en todas las				

áreas de trabajo.

3. Corto plazo: Adquirir y utilizar patch cords flexibles de fábrica para la conexión final.

VII. HALLAZGOS DE ARQUITECTURA LÓGICA Y SEGURIDAD DE RED

HALLAZGO No. H-RED-LOG-01

SILAIS – SEDE MASAYA		REF: H-RED-LOG-01		
HALLAZGOS DE LA AUDITORIA		H4		
PROCESO AUDITADO	Seguridad de las comunicaciones – Segmentación de red	PAGINA		
		1	DE	1
RESPONSABLE				
CRITERIO	ISO 27001 A.13.1.1, COBIT DSS05, Ley 921			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS05 – Gestión de Servicios de Seguridad	
DESCRIPCIÓN DEL HALLAZGO				
La red LAN del SILAIS – Sede Masaya opera bajo una topología de red plana sin segmentación VLAN. Todas las áreas funcionales, incluyendo áreas críticas que manejan datos sensibles (Epidemiología, Banco Biológico), comparten el mismo dominio de broadcast con áreas administrativas y de uso compartido. Los switches Fast Ethernet, al no ser administrables, carecen de la capacidad técnica para implementar VLANs o listas de control de acceso.				
CAUSAS				
• Obsolescencia tecnológica de los switches Fast Ethernet, que no soportan la funcionalidad de segmentación lógica. • Falta de un diseño de arquitectura de red que contemple la separación por niveles de sensibilidad de datos. • Inexistencia de políticas de seguridad de la información que exijan la segmentación como control.				
EVIDENCIA				
• Pruebas de conectividad (comando ping) exitosas entre equipos de "Varios 1" y equipos de "Epidemiología" y "Banco Biológico", confirmando la ausencia de restricciones. • Checklist Módulo IV (Arquitectura Lógica), criterio S-02: ¿Están configuradas Redes Virtuales (VLANs)? Respuesta: NO.				
IMPACTO				
• Movimiento lateral sin restricciones para malware; un ataque de ransomware originado en un área de uso compartido puede cifrar datos en áreas críticas. • Acceso no autorizado a datos sensibles de pacientes desde cualquier punto de la red. • Incumplimiento de la Ley 921 de Protección de Datos Personales.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado		Impacto	Probabilidad	Nivel de

R-RED-002: Cifrado de datos SISNIVEN por ransomware propagado en red plana	Catastrófico Alta (4) (5)	Riesgo Extremo (20)
RECOMENDACIONES		
1. Prioritaria (30-60 días): Reemplazar los switches Fast Ethernet por switches Gigabit administrables con soporte para VLANs (802.1Q). 2. Al momento del reemplazo: Configurar la segmentación VLAN para aislar el tráfico de las áreas críticas (Epidemiología, Banco Biológico) del resto de la red. 3. Implementar Listas de Control de Acceso (ACLs) entre las VLANs para reforzar la seguridad.		

HALLAZGO No. H-RED-LOG-02

SILAIS – SEDE MASAYA			REF: H-RED-LOG-02		
HALLAZGOS DE LA AUDITORIA			H5		
PROCESO AUDITADO	Seguridad de la red inalámbrica		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	ISO 27001 A.11.2.2, COBIT DSS05				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS05 – Gestión de Servicios de Seguridad		
DESCRIPCIÓN DEL HALLAZGO					
Catorce equipos en áreas funcionales críticas (Estadística, Contabilidad, Insumos Médicos, Enfermería y RRHH) dependen exclusivamente de conectividad WiFi para sus operaciones, sin disponer de puntos de red cableada como respaldo. Adicionalmente, se desconoce la configuración de seguridad de la red inalámbrica, ya que no existe documentación sobre el protocolo de cifrado (WPA2, WPA3), el mecanismo de autenticación utilizado ni la intensidad de la señal en los puntos de trabajo.					
CAUSAS					
• Planificación de la infraestructura de conectividad sin considerar la redundancia en áreas críticas. • Instalación de puntos de acceso WiFi sin el tendido paralelo de cableado UTP. • Ausencia de una gestión proactiva de la red que evalúe y documente las configuraciones de seguridad.					
EVIDENCIA					
• Tabla de distribución de conectividad por área funcional, que documenta la dependencia WiFi. • Checklist Módulo III, criterio E-06: ¿Las áreas críticas cuentan con puntos de red cableada como respaldo? Respuesta: NO.					
IMPACTO					
• Interrupción de la conectividad en procesos críticos de consolidación de datos estadísticos y gestión de inventario farmacéutico ante una caída de la señal WiFi. • Riesgo de interceptación de tráfico sensible (Man-in-the-Middle) si el protocolo de cifrado es débil o inexistente.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado		Impacto	Probabilidad	Nivel de	

R-RED-004: Interceptación de credenciales y datos vía WiFi	Crítico (4)	Media-Alta (4)	Riesgo Extremo (16)
R-RED-006: Exposición de datos por WiFi con cifrado débil	Alto (3)	Media (3)	Alto (9)
RECOMENDACIONES			
1. Corto plazo (30-60 días): Instalar puntos de red cableada como conexión principal en las áreas críticas, dejando la conectividad WiFi como respaldo. 2. Inmediata (0-15 días): Verificar y documentar el protocolo de cifrado y autenticación de los puntos de acceso; si es inferior a WPA2, planificar su actualización a WPA3.			

III. HALLAZGOS DE GESTIÓN Y GOBERNANZA DE LA RED

HALLAZGO No. H-RED-GOB-01

SILAIS – SEDE MASAYA		H-RED-GOB-01		
HALLAZGOS DE LA AUDITORIA		H6		
PROCESO AUDITADO	Gestión de Incidentes de Red		PAGINA	
			1	DE 1
RESPONSABLE				
CRITERIO	ISO 27001 A.16.1, COBIT DSS02			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS02 – Gestión de Solicitudes e Incidentes	
DESCRIPCIÓN DEL HALLAZGO				
No existe un procedimiento formal ni una herramienta (como un sistema de tickets) para el registro, seguimiento y resolución de incidentes de red. Las fallas de conectividad se reportan de manera verbal o informal a personas que, sin designación oficial, intentan resolverlas. No se genera documentación que permita analizar la recurrencia de los problemas.				
CAUSAS				
• Inexistencia de un administrador de red responsable de la gestión de incidentes. • Falta de implementación de un sistema de mesa de ayuda básico. • Cultura organizacional reactiva que no prioriza el registro de eventos.				
EVIDENCIA				
• Entrevistas con el personal de las áreas de Epidemiología, Estadística y Planificación, quienes confirmaron el procedimiento informal. • Checklist de gestión de red, criterio DSS02: ¿Existe un registro formal de incidentes de red? Respuesta: NO.				
IMPACTO				
• Tiempos de respuesta y resolución de fallos excesivos y no controlados. • Imposibilidad de identificar problemas recurrentes o medir la calidad del servicio de red.				

Sensación de desamparo en los usuarios al no tener un canal claro de reporte.			
VALORACIÓN DEL RIESGO			
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo
Proceso DSS02 no implementado: Respuesta ineficiente a incidentes	Alto (3)	Muy Alta (5)	Alto (15)
RECOMENDACIONES			
- Corto plazo: Designar al responsable de red como punto único de contacto para el reporte de incidentes. - Corto plazo: Implementar un sistema de tickets simple (puede ser una hoja de cálculo compartida o una herramienta gratuita) para registrar, dar seguimiento y documentar la resolución de cada incidente.			

HALLAZGO No. H-RED-GOB-02

SILAIS – SEDE MASAYA		H-RED-GOB-02		
HALLAZGOS DE LA AUDITORIA		H7		
PROCESO AUDITADO	Gestión de la Continuidad de la Red	PAGINA		
		1	DE	1
RESPONSABLE				
CRITERIO	COBIT DSS04, ISO 27001 A.17.2			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS04 – Gestión de la Continuidad	
DESCRIPCIÓN DEL HALLAZGO				
El SILAIS – Sede Masaya no cuenta con un Plan de Continuidad de Negocio o Recuperación ante Desastres (BCP/DRP) para la infraestructura de red. No existen procedimientos documentados que describan las acciones a tomar para restablecer la conectividad en caso de un fallo catastrófico del switch principal, la pérdida del enlace con el MINSA Central o cualquier otro incidente que paralice las comunicaciones.				
CAUSAS				
• Inexistencia de un responsable de TI que impulse la elaboración del plan. • Falta de conciencia sobre la dependencia crítica de la institución en la conectividad de red para la operación del SISNIVEN. • Ausencia de una política institucional de continuidad del negocio.				
EVIDENCIA				
• Inexistencia de un responsable de TI que impulse la elaboración del plan. • Falta de conciencia sobre la dependencia crítica de la institución en la conectividad de red para la operación del SISNIVEN. • Ausencia de una política institucional de continuidad del negocio.				
IMPACTO				

- Inexistencia de un responsable de TI que impulse la elaboración del plan.
- Falta de conciencia sobre la dependencia crítica de la institución en la conectividad de red para la operación del SISNIVEN.
- Ausencia de una política institucional de continuidad del negocio.

VALORACIÓN DEL RIESGO

Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo
R-RED-001: Colapso total de la LAN por fallo catastrófico	Catastrófico (5)	Alta (4)	Extremo (20)

RECOMENDACIONES

1. Inmediato (0-15 días): Convocar a un grupo de trabajo multidisciplinario para la elaboración del Plan de Continuidad y Recuperación ante Desastres de la red.
2. Corto plazo (30-60 días): Documentar el plan, definiendo roles, procedimientos de recuperación, RTOs (Recovery Time Objectives) y un listado de contactos de emergencia. Realizar una prueba de escritorio del plan.

VII. ANEXOS

Anexo 1. Organigrama del SILAIS Sede Masaya



Anexo 2. Listado de verificación (Checklist) – Auditoria de red y hardware

SILAIS - SEDE MASAYA

MÓDULO I: INFRAESTRUCTURA FÍSICA DE RED Y ÁREA DE COMUNICACIONES

Referencia Normativa: ANSI/TIA/EIA-569 (Espacios y Canalizaciones), ANSI/TIA/EIA-568-C (Cableado Comercial) e ISO/IEC 27001:2022 (A.11 Seguridad Física).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
F-01	¿Los equipos de red centrales (Switch Principal de 24 puertos ubicado en Dirección y Switch Secundario de 24 puertos ubicado en Varios 1) están alojados de forma segura dentro de un Gabinete o Rack cerrado con llave?	ISO 27001 (A.11.1.1)	☐	☐	☐	
F-02	¿Existe un Patch Panel para la terminación mecánica del cableado rígido que proviene de las 14 áreas funcionales, o los cables están terminados directamente con conectores RJ45 hacia los switches?	ANSI/TIA-568-C	☐	☐	☐	
F-03	¿La distribución de energía para los switches se realiza a través de una regleta de alimentación segura o PDU, con protección contra sobrecargas?	TIA-942 / ISO 27001 (A.11.2.2)	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
F-04	¿Cada switch cuenta con respaldo de energía ininterrumpida mediante una UPS operativa y con baterías en buen estado?	ISO 27001 (A.11.2.2)	☐	☐	☐	
F-05	¿El área donde se ubican los switches (Dirección y Varios 1) cuenta con ventilación adecuada y está libre de acumulación de polvo volcánico?	ANSI/TIA-569-C	☐	☐	☐	
F-06	¿Los switches están ubicados sobre una superficie estable y segura, o sobre escritorios de madera expuestos a manipulación accidental?	ISO 27001 (A.11.1.3)	☐	☐	☐	
F-07	¿Se ha verificado visualmente el estado de los LEDs de diagnóstico de los switches (Power, Link/Act) para confirmar operación normal?	Mejores Prácticas	☐	☐	☐	

MÓDULO II: SUBSISTEMA DE CABLEADO HORIZONTAL Y CANALIZACIÓN

Referencia Normativa: ANSI/TIA/EIA-568-C (Cableado Comercial) y ANSI/TIA/EIA-569-C (Canalizaciones y Espacios).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
C-01	¿El 100% de la trayectoria de los cables que conectan las 14 áreas funcionales se encuentra protegida dentro de canaletas plásticas de PVC?	ANSI/TIA-569-C	☐	☐	☐	
C-02	¿Las áreas de Banco Biológico, Sindicato, Dirección y FET Salud cuentan con canaletas plásticas instaladas?	ANSI/TIA-569-C	☐	☐	☐	
C-03	¿Las 10 áreas funcionales restantes (Epidemiología, Varios 1, 2 y 3, Estadística, Contabilidad, RRHH, Insumos Médicos, Enfermería, Administración, Caja, SNC) cuentan con canaletas plásticas o tienen el cableado expuesto?	ANSI/TIA-569-C	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
C-04	¿Se respetan los radios de curvatura del cableado UTP en todas las trayectorias para evitar daños internos a los conductores?	ANSI/TIA-568-C	☐	☐	☐	
C-05	¿El cableado horizontal está correctamente etiquetado o identificado en ambos extremos (área de switch y área de trabajo)?	ANSI/TIA-606-B	☐	☐	☐	
C-06	¿Se utiliza cable UTP de categoría adecuada (Cat5e o superior) que soporte al menos 100 Mbps en todos los tendidos?	ANSI/TIA-568-C	☐	☐	☐	
C-07	¿Los cables están terminados directamente con conectores RJ45 macho hacia los switches, sin utilizar Patch Panels intermedios?	ANSI/TIA-568-C	☐	☐	☐	
C-08	¿Se han realizado	Mejores	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
	pruebas de continuidad con Cable Tester en los puntos de red de las áreas críticas (Epidemiología, Estadística, Banco Biológico, Contabilidad, Dirección)?	Prácticas				
C-09	¿La norma de ponchado utilizada en los conectores RJ45 corresponde a la configuración T568A en ambos extremos?	ANSI/TIA-568-C	☐	☐	☐	

MÓDULO III: ÁREA DE TRABAJO (ENDPOINTS) Y TERMINACIONES FÍSICAS

Referencia Normativa: ANSI/TIA/EIA-568-C (Área de Trabajo) y ANSI/TIA/EIA-606-B (Administración y Etiquetado).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
E-01	¿Las áreas de trabajo cuentan con rosetas de pared (faceplates) o cajas de superficie donde se terminan los cables de red?	ANSI/TIA-568-C	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
E-02	¿Los puntos de red están terminados con conectores RJ45 hembra (jacks) montados en placa, o los cables cuelgan directamente de la pared con un conector RJ45 macho?	ANSI/TIA-568-C	☐	☐	☐	
E-03	¿La conexión final entre el punto de red de la pared y las computadoras se realiza utilizando Patch Cords flexibles de fábrica?	ANSI/TIA-568-C	☐	☐	☐	
E-04	¿Los puntos de red en las áreas de trabajo están etiquetados formalmente con una nomenclatura que permita identificar su ubicación en el switch o área correspondiente?	ANSI/TIA-606-B	☐	☐	☐	
E-05	¿Los 46 equipos de escritorio y 5 laptops tienen acceso físico a un punto de red o dependen exclusivamente de	Mejores Prácticas	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
	conectividad WiFi?					
E-06	¿Las áreas de Estadística (2 equipos WiFi), Contabilidad (3 equipos WiFi), Insumos Médicos (3 equipos WiFi), Enfermería (2 equipos WiFi) y RRHH (2 equipos WiFi) cuentan con puntos de red cableada como respaldo?	Mejores Prácticas	☐	☐	☐	

MÓDULO IV: ARQUITECTURA LÓGICA DE RED (CAPA 2 Y CAPA 3)

Referencia Normativa: ISO/IEC 27001:2022 (A.13 Seguridad de las Comunicaciones) y COBIT 2019 (DSS05 Gestión de Servicios de Seguridad).

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
S-01	¿Los switches Fast Ethernet de 24 puertos son administrables y permiten la configuración de VLANs, QoS, seguridad de puertos y monitoreo?	ISO 27001 (A.13.1.1)	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
S-02	¿Están configuradas Redes Virtuales (VLANs) para separar el tráfico de datos sensibles (Epidemiología, Banco Biológico) del tráfico administrativo (Contabilidad, RRHH) y del tráfico de áreas de uso compartido (Varios 1, 2 y 3)?	ISO 27001 (A.13.1.1)	☐	☐	☐	
S-03	¿La topología de red actual es plana (un solo dominio de broadcast) sin segmentación lógica entre las 14 áreas funcionales?	ISO 27001 (A.13.1.3)	☐	☐	☐	
S-04	¿Se ha verificado la velocidad de negociación de los enlaces en los equipos de cómputo, confirmando que operan a 100 Mbps debido a la limitación de los switches Fast Ethernet?	Mejores Prácticas	☐	☐	☐	
S-05	¿El direccionamiento IP está correctamente	Mejores Prácticas	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
	configurado mediante DHCP o asignación estática documentada para todas las áreas?					
S-06	¿Existen Listas de Control de Acceso (ACLs) o reglas de firewall que restrinjan la comunicación entre áreas con diferentes niveles de sensibilidad de datos?	ISO 27001 (A.13.1.1)	☐	☐	☐	
S-07	¿La red inalámbrica (WiFi) utilizada en Estadística, Contabilidad, Insumos Médicos, Enfermería y RRHH cuenta con protocolo de cifrado WPA2 o superior?	ISO 27001 (A.11.2.2)	☐	☐	☐	
S-08	¿Se ha verificado la intensidad de señal WiFi en los puntos de trabajo de las áreas críticas, asegurando un nivel superior a -67 dBm?	Mejores Prácticas	☐	☐	☐	
S-09	¿Las conexiones	ISO	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
	privadas a Internet en Sindicato, SNC y Transporte están documentadas, autorizadas y cuentan con medidas de seguridad para prevenir fuga de información institucional?	27001 (A.13.1.1)				

MÓDULO V: SEGURIDAD DE LA INFORMACIÓN Y CONTROL DE ACCESO A LA RED

Referencia Normativa: ISO/IEC 27001:2022 (A.9 Control de Acceso, A.12 Seguridad de las Operaciones) y COBIT 2019 (DSS05).

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
G-01	¿Existe un procedimiento formal para la autorización y registro de nuevos dispositivos que se conectan a la red del SILAIS?	ISO 27001 (A.9.1.1)	☐	☐	☐	
G-02	¿Se ha implementado control de acceso a la red mediante autenticación 802.1X o seguridad de puertos en los switches?	ISO 27001 (A.9.4.2)	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
G-03	¿Se monitorea el tráfico de red para detectar actividades anómalas, intentos de acceso no autorizado o saturaciones de ancho de banda?	ISO 27001 (A.12.4.1)	☐	☐	☐	
G-04	¿Existe un registro (bitácora) de incidentes de seguridad de red, incluyendo caídas de conectividad, lentitud extrema o intentos de intrusión?	ISO 27001 (A.16.1.5)	☐	☐	☐	
G-05	¿Se realizan copias de seguridad (backups) de las configuraciones de los dispositivos de red (switches, puntos de acceso)?	COBIT 2019 (DSS04)	☐	☐	☐	
G-06	¿Existe un Plan de Continuidad de Negocio o Recuperación ante Desastres que contemple el fallo de los switches principales o la pérdida de conectividad con el MINSA Central?	COBIT 2019 (DSS04)	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
G-07	¿Se dispone de un switch de respaldo para reemplazar rápidamente un equipo fallado y restablecer la conectividad en las áreas críticas?	COBIT 2019 (DSS04)	☐	☐	☐	

MÓDULO VI: GESTIÓN DE ACTIVOS DE RED Y DOCUMENTACIÓN

Referencia Normativa: COBIT 2019 (DSS01 – Gestión de Operaciones) e ISO/IEC 27001:2022 (A.8 Gestión de Activos).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
A-01	¿Existe un inventario formal, actualizado y documentado de todos los activos de red (switches, UPS, puntos de acceso, cableado estructurado)?	COBIT 2019 (DSS01)	☐	☐	☐	La gestión de inventarios de infraestructura es una práctica operativa fundamental dentro de DSS01.

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
A-02	¿El inventario incluye información sobre: marca, modelo, número de serie, fecha de adquisición, estado de garantía y ubicación física de cada activo de red?	ISO 27001 (A.8.1.1)	☐	☐	☐	
A-03	¿Se ha definido un responsable o propietario para cada activo de red crítico?	ISO 27001 (A.8.1.2)	☐	☐	☐	
A-04	¿Existe un diagrama de topología de red actualizado que muestre la interconexión de los switches, puntos de acceso y la distribución hacia las 14 áreas funcionales?	Mejores Prácticas (alineado a DSS01)	☐	☐	☐	Mantener documentación actualizada de la topología es parte de la operación diaria (DSS01).
A-05	¿Se ha documentado la antigüedad y el ciclo de vida estimado de los switches Fast Ethernet para planificar su renovación tecnológica?	COBIT 2019 (DSS01)	☐	☐	☐	El seguimiento del ciclo de vida y la planificación del reemplazo se gestionan dentro de las operaciones (DSS01).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
A-06	¿Existe un procedimiento formal para la baja y disposición segura de equipos de red obsoletos o dañados?	ISO 27001 (A.8.3.2), COBIT 2019 (DSS01)	☐	☐	☐	La disposición segura es una tarea operativa que debe estar documentada (DSS01).

Auditor Responsable: _____

Fecha de Verificación: _____ / _____ / 2026

Firma del Auditor: _____

Anexo 3. Evidencias de auditoria

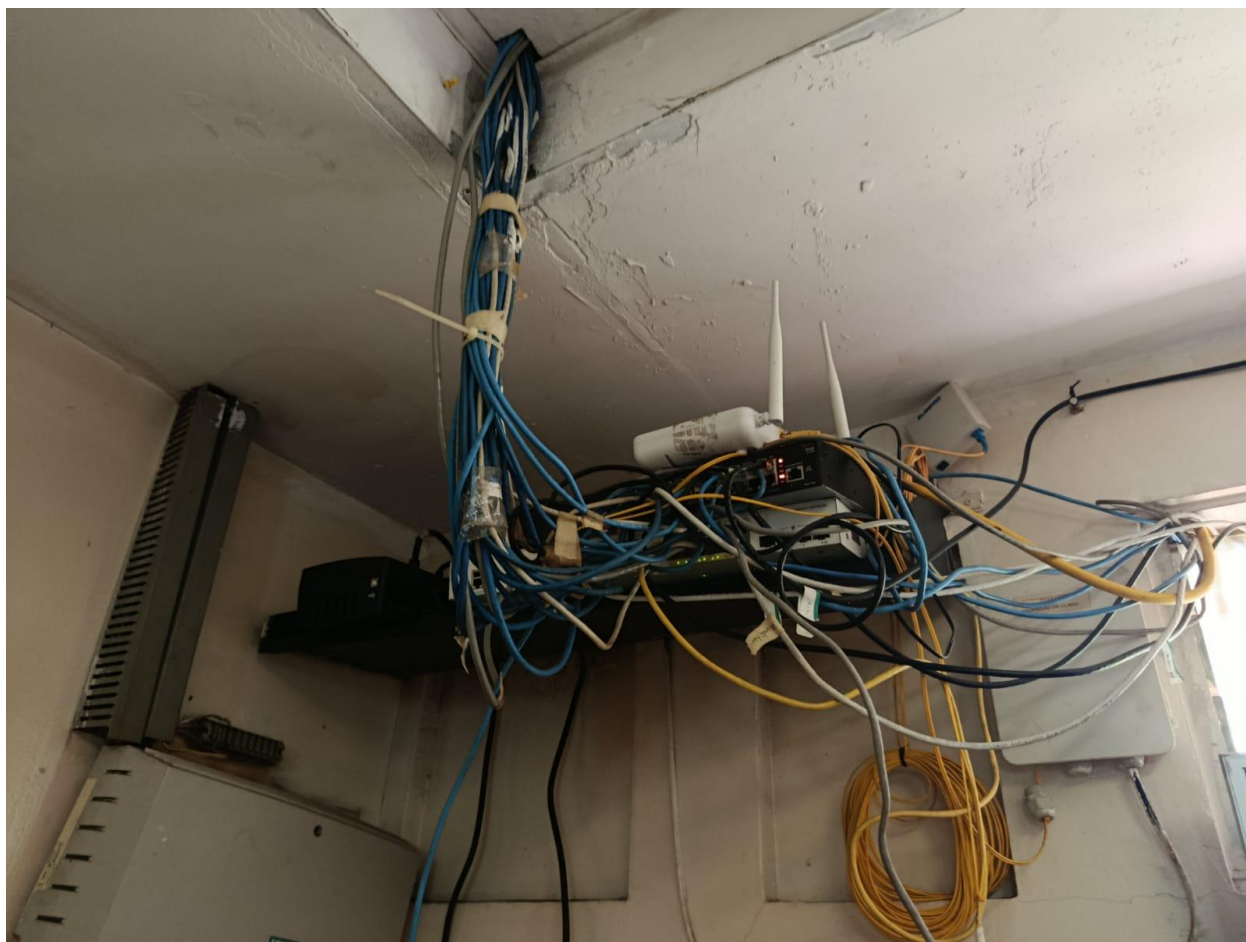


Imagen 1. Los dos switches principales ubicados en el área de Dirección no cuentan con un con un Rack ni con un patch panel.



Imagen 2. El tercer switch que se encuentra en la oficina 'Varios 1' no cuentan con un con un Rack ni con un patch panel.

